

RESUMEN SEGURIDAD Y PROTECCIÓN EN REDES DE COMUNICACIÓN

Seguridad y Protección en Redes de Comunicaciones	1
Definiciones Técnicas Literales	1
Clasificación de Medidas de Seguridad	2
Amenazas y Ataques a las Conexiones	2
Seguridad Perimetral	3
Concepto y Zonas de Red	3
Cortafuegos (Firewalls)	3
Detección y Prevención de Intrusiones (IDS/IPS)	5
Servidor Proxy	5
Acceso Remoto Seguro a Redes	6
Arquitecturas de Acceso	6
Recomendaciones de Seguridad (Normativa)	6
Redes Privadas Virtuales (VPN)	7
Clasificación por Capa OSI	7
Protocolo IPsec: Modos de Funcionamiento	7
Soluciones Específicas	8
Seguridad en el Puesto del Usuario	8
Medidas Técnicas y de Control	8
Herramientas del CCN-CERT para el Puesto	9

Seguridad y Protección en Redes de Comunicaciones

Definiciones Técnicas Literales

- **Seguridad:** "Capacidad de las redes o de los sistemas de información de resistir, con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que comprometan la disponibilidad, autenticidad, integridad y confidencialidad de los datos almacenados o transmitidos".

- **Dimensiones de la Seguridad (ACIDT):** Es necesario proteger la **Autenticidad, Confidencialidad, Integridad, Disponibilidad y Trazabilidad**.
- **Zero Trust (Confianza Cero):** "Modelo que asume que nada fuera o dentro de la organización es confiable, y que se debe identificar y autenticar a cualquier persona o entidad que intente conectarse, antes de permitir su acceso".

Clasificación de Medidas de Seguridad

- **TRANSEC (Seguridad de las Transmisiones):** Medidas que aseguran los canales de transmisión.
- **COMPUSEC (Seguridad de los Ordenadores):** Medidas que protegen el proceso automático de datos.
- **NETSEC (Seguridad de las Redes):** Medidas que protegen los elementos de red.
- **CRYPTOSEC (Seguridad Criptológica):** Medidas que aseguran que la información está protegida mediante procedimientos criptográficos.

Amenazas y Ataques a las Conexiones

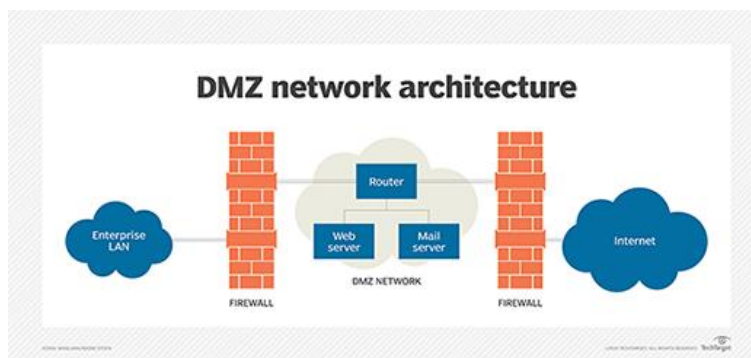
- **Spoofing:** "Técnica de suplantación de identidad a través de la Red, llevada a cabo por un intruso... pone en riesgo la privacidad así como la integridad de los datos".
- **Sniffing:** "Técnica que utiliza un programa que analiza el tráfico que pasa a través de una red (sniffer). Se utiliza para capturar información de autenticación u otra información sensible".
- **Man in the middle (MITM):** "Ataque donde el atacante se sitúa entre el usuario y el servidor interceptando la información intercambiada".
- **Eavesdropping:** "Ataque que tiene por objeto obtener información sin modificarla".
- **Vishing:** Suplantación a través de llamadas telefónicas.

Enfoque CPS: El tribunal suele preguntar por la dimensión de la seguridad afectada en un supuesto. Un distractor común es afirmar que el **sniffing** afecta a la integridad (falso, afecta a la **confidencialidad**).

Seguridad Perimetral

Concepto y Zonas de Red

- **Red Perimetral:** "Conjunto de dispositivos y/o mecanismos técnicos que son utilizados para separar la red interna de una organización (intranet) del resto de redes externas (Internet)".
- **DMZ (De-Militarized Zone / Zona Desmilitarizada):** "Redes con un nivel de protección intermedio entre las internas y las externas". **Diseño físico:**
 - **Bastion Host (Host Bastión):** El equipo expuesto directamente a Internet que ha sido "fortalecido" (eliminando servicios innecesarios).
 - **Arquitectura de un solo firewall (Three-homed):** Un solo firewall con tres patas: Internet, Red Interna y DMZ.
 - **Arquitectura "Back-to-Back" (Screened Subnet):** Dos firewalls en serie; la DMZ queda "atrapada" entre el firewall externo y el interno. Es la más segura y la que más preguntan.



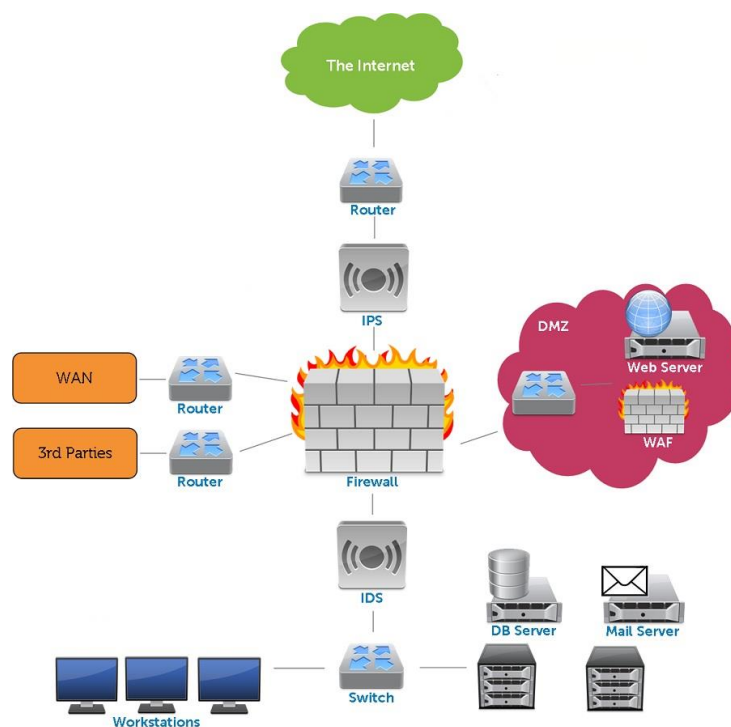
- **Portal Cautivo:** "Página web que gestiona el acceso de los usuarios a una red, generalmente inalámbrica".

Cortafuegos (Firewalls)

"Elemento de seguridad perimetral" que se clasifica según su nivel OSI:

- **Filtrado de paquetes básico (Capa 3 y 4):** "Realiza decisiones basándose en la información de las cabeceras: dirección IP origen/destino, puerto origen/destino y protocolo".

- **Inspección de Estado (Stateful Inspection):** Realiza un seguimiento de las conexiones activas. Si el firewall ve un paquete que no pertenece a una conexión abierta, lo bloquea.
- **Application Level Gateway (Proxy Firewall):** Trabaja en la **Capa 7 (Aplicación)**. Entiende el protocolo (ej. sabe si un comando de FTP es lícito o no).
- **Next-Generation Firewall (NGFW):** Combina los anteriores con **DPI (Deep Packet Inspection)**, antivirus y detección de intrusiones en un solo equipo.
- **Filtrado de paquetes con estado e inspección (DPI - Deep Packet Inspection):** "Añade la capacidad de inspeccionar el contenido de los paquetes, interpretando los protocolos o aplicaciones que viajan dentro de los datagramas".
- **WAF (Web Application Firewall):** "El WAF es un firewall especializado que opera exclusivamente en la **Capa 7 (Aplicación)**. Su función principal es proteger servidores web de ataques específicos como **Inyección SQL (SQLi)** y **Cross-Site Scripting (XSS)**, analizando el tráfico HTTP/HTTPS en profundidad."



- **Cortafuegos Transparente:** "Aquel que funciona en la capa 2 (enlace de datos) pero es capaz de modificar paquetes en tránsito. No requiere dirección IP para su operación nominal".

Tabla de Reglas Literales de un Cortafuegos:

Protocolo	Dir. Origen	Puerto Origen	Dir. Destino	Puerto Destino	Acción
TCP	Cualquiera	Cualquiera	1.2.3.4	25 (SMTP)	✓ ACEPTAR
TCP	Cualquiera	Cualquiera	1.2.3.5	80 (HTTP)	✓ ACEPTAR
TCP	Cualquiera	Cualquiera	Cualquiera	Cualquiera	✗ DENEGAR

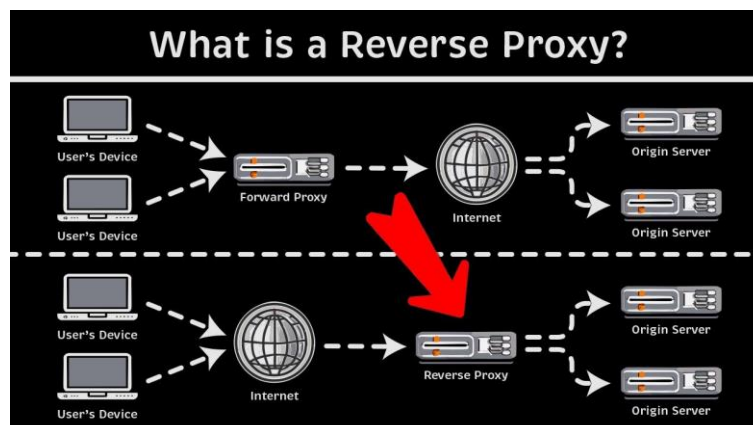
Detección y Prevención de Intrusiones (IDS/IPS)

- **IDS (Intrusion Detection System):** Es pasivo. Detecta el ataque, genera la alerta y hace el log, pero **no lo detiene**.
- **IPS (Intrusion Prevention System):** Es activo. Se sitúa "in-line" (en medio del tráfico) y **bloquea el ataque** en tiempo real.
- Tip: Ambos pueden basarse en firmas (patrones conocidos) o en **comportamiento/anomalías**.

Servidor Proxy

"Dispositivos de protección de perímetro que hacen de intermediarios en distintos protocolos de aplicación".

- **Tipos según su Función (Ubicación):**
 - **Forward Proxy (Directo):** Actúa en nombre del **cliente**. Protege la red interna y controla el acceso de los usuarios hacia Internet (ej. filtrar webs prohibidas).
 - **Reverse Proxy (Inverso):** Actúa en nombre del **servidor**. Protege los servidores internos, recibiendo las peticiones de Internet para balancear carga o cifrar tráfico SSL/TLS.



- **Clasificación Técnica:**

- **Proxy a nivel de circuito:** "Opera en la capa de transporte. Monitoriza paquetes TCP/UDP y no inspecciona la capa de aplicación. El más conocido es **Socks**".
- **Proxy NAT (Network Address Translation):** Procedimiento para "modificar las direcciones IP origen o destino de las cabeceras... denominado enmascaramiento de direcciones IP (**IP Masquerading**)".
- **Proxy Web Cache:** "Almacena en una caché las páginas web visitadas para mejorar la navegación y optimizar el canal de acceso". Ejemplo: **SQUID**.

Enfoque CPS: Una pregunta recurrente es la ubicación de los servidores en una arquitectura segura: los buzones de correo y servidores web deben estar en la **DMZ**. Un distractor habitual en el examen es situar la base de datos de usuarios en la DMZ (incorrecto, debe ir en la red interna tras un segundo cortafuegos).

Acceso Remoto Seguro a Redes

Arquitecturas de Acceso

- **Portal Web:** Interfaz centralizada que ofrece acceso a servicios específicos sin requerir software cliente adicional (usa el navegador).
- **Escritorio Remoto (Remote Desktop):** "Permite al usuario controlar el teclado y ratón del ordenador remoto y ver su pantalla".
- **VDI (Virtual Desktop Infrastructure):** Acceso a un entorno de escritorio completo ejecutado en servidores centrales.

Recomendaciones de Seguridad (Normativa)

- **Gestión de privilegios:** "Los privilegios de acceso remoto a recursos por parte del teletrabajador **NO** serán los mismos que cuando se trabaja en local" (deben ser menores/específicos).
- **Doble factor de autenticación (2FA):** Validación mediante un código adicional (ej. SMS) tras la contraseña.

Redes Privadas Virtuales (VPN)

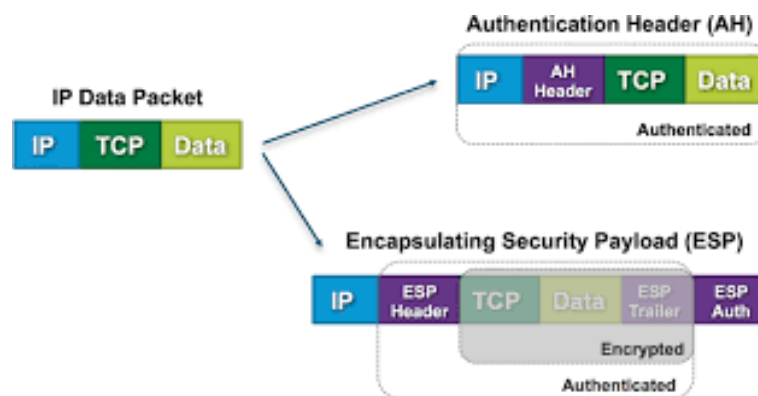
"Tecnología que establece una conexión virtual segura, conocida como '**túnel**', construida sobre una red física insegura (Internet)".

Clasificación por Capa OSI

1. **Nivel de Enlace (Capa 2):** Protegen el enlace físico.
Protocolos: **MACsec (IEEE 802.1AE)**.
 - Protocolos vulnerables: **PPTP** (RFC 2637), **L2TP** (RFC 2661) y **L2F**.
2. **Nivel de Red (Capa 3):** Protegen datos y cabeceras IP.
Protocolos: **IPsec** (RFC 4301) y **WireGuard**.
3. **Nivel de Transporte (Capa 4):** Protocolo más empleado: **SSL/TLS**.
4. **Nivel de Aplicación (Capa 7):** Basadas en **SSH**.

Protocolo IPsec: Modos de Funcionamiento

- **Modo Transporte:** "Sencillamente se añade una cabecera IPsec al paquete IP, manteniendo la cabecera original (no oculta la red)". Sólo la carga útil es cifrada.
- **Modo Túnel:** "Todo el paquete IP original se convierte en carga útil (**payload**) de un nuevo paquete IP... permite ocultar la información de red de ambas entidades".
- **Protocolos internos:**
 - **AH (Authentication Header):** Proporciona Autenticidad e Integridad, pero **NO proporciona Confidencialidad** (no cifra los datos).
 - **ESP (Encapsulating Security Payload):** Proporciona **Confidencialidad** (cifra el paquete), además de integridad y autenticidad. Es el más usado hoy en día.



Soluciones Específicas

- **OpenVPN:** Framework basado en software libre que utiliza el estándar **SSL/TLS**.
- **VPNaaS (VPN as a Service):** Proporciona un punto único de acceso seguro a la nube o centro de datos sin gestionar infraestructura propia.

Enfoque CPS: El tribunal suele preguntar qué protocolos **NO** se usan para cifrado en VPN, siendo **KSEC 1.1** y **P2TP** los distractores estrella. También es vital recordar que las VPN se pueden establecer en las **capas 2 y 3** de OSI.

Seguridad en el Puesto del Usuario

Medidas Técnicas y de Control

- **AppLocker:** Característica de Windows para especificar qué usuarios pueden ejecutar determinadas aplicaciones.
- **BitLocker:** Herramienta para el cifrado de dispositivos; su clave es necesaria para restaurar copias de seguridad de discos cifrados.
- **Limitar el Acceso:** Se debe restringir la conexión de dispositivos **BYOD** (Bring Your Own Device) y mantener una base de datos de los mismos.
- **Honeypots (Sistemas Trampa):** "Recurso de red (servidor o servicio ficticio) diseñado para ser atacado. Su objetivo es distraer al atacante, alertar sobre su presencia y estudiar sus técnicas sin poner en riesgo los activos reales de la organización."

Herramientas del CCN-CERT para el Puesto

- **CLAUDIA:** Detección de amenazas complejas (**APT - Advanced Persistent Threats**) y movimiento lateral en el puesto del usuario.
- **MARÍA:** Análisis estático de código dañino para plataformas Windows y Linux.
- **EMMA:** Proporciona visibilidad y control sobre la red.
- **LUCÍA:** Gestión de incidentes de ciberseguridad.
- **SIEM (Security Information and Event Management)**
 - **Definición:** "Sistema centralizado que recolecta, normaliza y analiza los logs (registros) de todos los dispositivos de red (firewalls, servidores, switches). Permite la correlación de eventos para detectar ataques complejos que pasan desapercibidos de forma aislada."
 - **Concepto clave:** Combina **SEM** (gestión de eventos en tiempo real) y **SIM** (almacenamiento y análisis de datos a largo plazo).

Enfoque CPS Final: Memorice que el **CCN recomienda** disponer del puerto 80 abierto pero configurado para realizar una **redirección automática a HTTPS (443)**. No confunda **Hoax** (mensaje inofensivo engañoso en cadena) con **Ransomware** (cifrado de archivos con rescate).